Lab 5: Static Code Analysis

Name: Samarth A Ambedkar **SRN:** PES1UG24AM243
Repo: https://github.com/SETAPESU26/L5_05_food_delivery **File:** `delivery_system.py`
Tools: Pylint, Bandit, Flake8

Summary of Results

Tool	Before	After
Pylint	6.27/10 (22 messages)	**10.00/10** (0 messages)
Bandit	3 issues (1 Medium, 2 Low)	**0 issues**
Flake8	12 issues	**0 issues** (empty report)

Commits

- **a914bf5** - Fix Bandit issues: pickle replaced with JSON, try/except/pass replaced with explicit validation
- **a217a75** - Fix Pylint issues: score 6.27 to 10.00
- **b2c6286** - Fix Flake8 issues: PEP 8 blank lines and line length

Issues Found and Fixed

Line numbers refer to the original file.

#	Issue	Tool / Code	Type	Severity	Line(s)	Description	Fix Approach
1	Unsafe deserialization	Bandit B301	Security	Medium	49	`pickle.load()` on a file can execute arbitrary code if the file is tampered with	Back up and restore orders as JSON; convert JSON string keys back to `int` ids on restore
2	Pickle import	Bandit B403	Security	Low	2	Importing `pickle` flags the module as a deserialization risk	Removed the import along with the pickle calls
3	Try / except / pass	Bandit B110, Pylint W0702, Flake8 E722	Security / Bug	Low	23-25	Bare `except: pass` hides every error, so an unknown order id (42) silently does nothing	Replaced with explicit checks: unknown status and unknown order id are reported and return `False`
4	Invalid status accepted	Logic (not flagged by tools)	Bug	High	21-23	`"teleported"` was stored as an order status; `VALID_STATUSES` was never used	Validate `status` against `VALID_STATUSES` before updating
5	Unknown dishes cost 99	Logic (not flagged by tools)	Bug	High	14-15	`menu.get(i, 99)` silently charged 99 for "sushi", which is not on the menu	Reject the order with `ValueError` listing the unknown dishes
6	Empty order accepted	Logic (not flagged by tools)	Bug	Medium	60, 64	An order with no customer and no items was created and marked delivered	Reject orders with no customer name or no items
7	Mutable default argument	Pylint W0102	Bug	Medium	11	`order_history=[]` is created once and shared across every call	Default to `None` and create a new list inside the function

#	Issue	Tool / Code	Type	Severity	Line(s)	Description	Fix Approach
8	Global statements	Pylint W0603	Design	Medium	12, 28, 48	`global next_id/menu/orders` makes state hard to follow and test	Mutate `orders`/`menu` in place (`clear()`/`update()`); derive the next id from `max(orders) + 1`
9	Files not closed safely	Pylint R1732, W1514	Bug	Medium	30, 43, 49	`open()` without `with` leaks the handle on error; no encoding given	Use `with open(..., encoding="utf-8")` everywhere
10	Broad exception	Pylint W0718	Bug	Medium	32	`except Exception` would also hide programming errors	Catch only `OSError` and `json.JSONDecodeError`
11	Naming / formatting	Pylint C0103, C0209	Style	Low	7, 51-52	`printQueue` is not snake_case; `%` formatting instead of f-string	Renamed to `print_queue`; switched to f-strings
12	Missing docstrings	Pylint C0114, C0116	Style	Low	1, all functions	No module or function documentation	Added a module docstring and one per function
13	Code runs on import	Best practice	Design	Low	70	`main()` ran whenever the module was imported	Wrapped in `if __name__ == "__main__":`
14	Blank lines	Flake8 E302, E305	Style	Low	11-70	One blank line between top-level functions instead of two	Two blank lines around every top-level function
15	Lines too long	Flake8 E501	Style	Low	16, 54	Lines longer than 79 characters	Wrapped the order dict and long expressions over several lines

Reflection

1. Which issues were the easiest to fix, and which were the hardest? Why?
The Flake8 issues were easiest: adding blank lines and wrapping long lines is mechanical and does not change behaviour. Missing docstrings and renaming `printQueue` were also quick. The hardest was replacing `pickle` with JSON (Bandit B301). JSON only allows string keys, so the integer order ids came back as `"1"`, `"2"` after a restore and had to be converted back. Removing the `global` statements was also harder, because I had to change how `orders`, `menu` and the next order id are managed without breaking the program.

2. Did the static analysis tools report any false positives? If so, describe one example.
Not strictly, but some warnings depend on context. Bandit B403 flags `import pickle` on its own even though importing it is harmless; only loading untrusted data is risky. In this program the backup file could be edited by anyone with disk access, so the warning was worth acting on. Pylint's W0603 (global statement) is a design warning, not a bug, and would be acceptable in a very small script. The tools also missed the most serious bugs: invalid statuses being stored, unknown dishes silently costing 99, and empty orders being accepted. Those were only found by running the program and reading its output.

3. How would you integrate static analysis tools into your software development workflow?
• Run Flake8 and Pylint in the editor so problems show up while typing.
• Add a pre-commit hook that runs Flake8, Pylint and Bandit and blocks commits that fail.
• Run all three in CI (for example GitHub Actions) on every push and pull request, and fail the build if the Pylint score drops below a threshold such as 9.5 or if Bandit reports Medium or High issues.
• Keep shared config files (`.pylintrc`, `.flake8`) in the repo so everyone uses the same rules.

4. What tangible improvements did you observe in the code quality, readability, and potential robustness after applying the fixes?
• **Security:** no more pickle deserialization, so a tampered backup file cannot run code.
• **Robustness:** errors are no longer swallowed. Invalid statuses, unknown order ids, unknown dishes and empty orders are reported instead of silently producing wrong data, so revenue and the queue are now correct.
• **Correctness:** the shared mutable default list is gone, and files are always closed, even on errors.
• **Readability:** docstrings, snake_case names, f-strings and PEP 8 formatting make the code easier to read. The Pylint score went from 6.27 to 10.00, and Bandit and Flake8 report no issues.